The Cost of Least Privilege:
A Field-Level Privilege Ablation for Multi-Agent EHR Data Quality Assurance

Mohsin Zafar

Graduate School of Professional and Continuing Studies, Fordham University

HINF 6497: Research Project/Thesis

Instructor: Michael Sanfilippo

August 7, 2026

Abstract

Data-quality checkers in electronic health records usually receive the whole record, a habit multi-agent clinical AI has inherited. Least privilege is a design principle and, for covered entities, a regulatory duty, but we found no field-granular measurement of its cost on a clinical task. Three designs run one task: a full-access **Baseline**, a field-projected **Confined**, and a **Tiered** one that moves identifier resolution into its own department. Confining cost nothing, though not for an interesting reason. Confined matches Baseline exactly on all three cohorts, at all manifest widths and four seeds. That is an identity rather than a measurement, because the two systems read the same three fields. Withholding one consumed field at a time measures the boundary. On the harder of two defect injectors, losing the unit costs 33.60 percentage points of detection, and the value or the analyte code 100.00. The one field released but never consumed cost nothing under either. Across these arms, projection was free where what is released covers what is consumed. Narrowing is also the wrong lever for privacy, because no width withholds the patient reference from the checks that read it. Resolving it once in that department and passing an opaque stand-in cuts inter-agent exposure, the share of Safe Harbor fields crossing agent boundaries, from 0.6079 to 0.0086, a fall of 98.6 per cent. Detection is unchanged on all three dimensions scored. Deleting linkage instead reaches the same exposure but collapses completeness to 0.1644. The stand-in does the work, not the deletion.

Contents

1 Introduction

EHR data is uneven: vitals go missing, values are physically impossible, records disagree across joins, and observations go stale. Secondary use therefore begins with a data-quality-assurance pass (Kahn et al., 2016), run by rule-checkers whose access is normally the entire record, and the habit persists when the work is split across agents.

Least privilege is a design principle (Saltzer & Schroeder, 1975). For covered entities it is a duty under the HIPAA minimum necessary standard at 45 C.F.R. §164.514(d) (Privacy of Individually Identifiable Health Information, 2013). That standard limits each class of worker to the protected health information (PHI) its function requires. Here that means the eighteen Safe Harbor identifier categories (U.S. Department of Health and Human Services, Office for Civil Rights, 2012).

The argument turns on four terms.

- **Manifest.** The list of fields one agent may read.
- **Projection.** What enforces it, building a reduced copy of the record from only those fields, so a field left out never reaches the agent.
- **Width.** How much a manifest releases, swept here from minimal to full.
- **Consumed.** A field a check reads, as against one merely released to it.

Least privilege's enforcement mechanisms stop above the field (Section 2): a SMART on FHIR scope (Mandel et al., 2016; HL7 International, 2024) reaches a resource type, never the fields within one. No such scope can say that a plausibility check may see an observation's value but not its subject reference. In the sources reviewed we found no pricing of field-level confinement on a clinical task.

Research question. What does it cost to show each checker less of the record, and which part of the system needs the patient's identity at all? **Aim.** To put a number on that cost, on one data-quality task. **Significance.** Least privilege below the resource type is at present asserted without a measured price, so a team choosing between whole-record access and a manifest has no figure to weigh. This study supplies one, on a single plausibility-centred task, three demonstration cohorts, one language model and three of the four quality dimensions scored. It settles nothing outside that setting, and what it prices is exposure, not re-identification risk.

Three contributions answer them. A field-granular privilege ablation prices what withholding one consumed field costs, with a released-but-unconsumed field as its negative control: confining each agent to a manifest costs nothing. But that zero is an identity rather than a measurement, since the confined and unconfined systems read the same three fields. A tiered design cuts inter-agent exposure by 98.6 per cent at no measured cost on the three dimensions scored. And the benchmark scores a correct detection as a false positive, which bounds what the cost comparisons run on it can claim.

2 Background and related work

2.1 The four quality dimensions, and least privilege

The four failures that open this paper come from two published taxonomies: completeness and plausibility from Kahn et al. (2016), consistency and timeliness from Weiskopf and Weng's (2013) concordance and currency. Consistency is raised to top level for cross-record checks. Conformance is skipped, staying within one lineage since Weiskopf and Weng are among Kahn's co-authors. Completeness carries the word both taxonomies leave implicit, missingness: Wells et al. (2013) find that missing values in EHR-derived data are seldom missing at random. An absent field is itself information, and the strategy chosen for handling it can change what the data support. None of this says what a checker must *see*: a plausibility check needs code, value and unit, hence whole-record access by default.

Saltzer and Schroeder (1975) ask the opposite, minimal privilege for every program and user, a concern with error as much as malice (Section 2.2). Three mechanisms grant it, each in a unit larger than the field.

- **Saltzer and Schroeder's own principle.** The unit is the principal.

- **The HIPAA minimum necessary standard.** The unit is the class of worker.
- **SMART on FHIR scopes.** The unit is the resource type, as in `patient/Observation.read` (Mandel et al., 2016; HL7 International, 2024).

None governs what one component hands another inside a pipeline, so a perimeter-compliant service can still hand every field to the checks behind it, as the full-access **Baseline** of Section 3.1 does.

2.2 What the literatures leave open, and what this study assumes

Three themes bear on this study, and each stops one step short of the same measurement.

Why exposure of a field matters. Identification does not need a name. Sweeney (2000) shows that ZIP code, birth date and sex in combination identify most of the US population uniquely. El Emam et al. (2011), reviewing published re-identification attacks on health data, find that attacks succeed far less often against data de-identified to a recognised standard than against data that was not. Between them these establish that quasi-identifiers moving between components are a documented risk, which is why a count of Safe Harbor fields crossing an agent boundary is worth taking. Neither supplies the inverse: no mapping in either turns such a count into a probability of re-identification, so a reduction in exposure remains a reduction in exposure.

Where a control can be placed. The unit each control chooses sets the floor on what can be withheld. Progent (Shi et al., 2025) puts policy at the tool-call boundary, governing what an agent may *do*, not what it may see. Jacob et al. (2025) come closest, separating privilege by data type so an injected instruction cannot travel with a value, but the unit is type, not field. Neupane et al. (2025) score sanitisation and policy against a HIPAA least-privilege requirement without measuring inter-agent handoffs. Together they establish that run-time confinement is buildable and auditable against a regulatory standard. All three stop above the field, and none reports what the confinement it imposes costs the task.

What escapes when nothing is enforced. This theme measures leakage without controlling it, and its two members agree on where it concentrates. AgentLeak (El Yagoubi et al., 2026) reports 27.2 per cent leakage in final outputs against 68.8 per cent in inter-agent messages, so output-only audits miss most of it. MAGPIE (Juneja et al., 2025) finds up to 50.7 per cent leakage across two hundred collaborative tasks, under explicit instruction not to disclose. Instruction alone is therefore not a sufficient control, and enforcement belongs at a boundary. What it yields is a channel and a rate. Both count what escapes without asking what the task loses when it is held back.

The three give a risk worth measuring, a boundary to enforce at and a channel to measure on. Among the sources reviewed we found none that does both: confine field by field on a clinical data-quality task, then report the cost.

This study's threat model concerns *mistakes*, not attackers: an agent holding patient data it never needed through a bug or misconfiguration. Projection (Section 1) rules out one such failure, since an absent field cannot be read. Four survive.

- **Over-granting.** A manifest may release more than the check needs, and projection faithfully delivers it. Enforcement is only as good as the declaration, and the ablation (Section 4.2) caught one such field.
- **Contents of a granted field.** A named field's contents may exceed the need, free text the plain case, since field granularity is not content granularity.
- **Onward leakage.** An agent may leak what it was legitimately given, to a log or a later tool call, which projection can only shrink.
- **Composition.** Two manifests, each minimal, may have projections that jointly re-identify a patient, a composition this study neither models nor bounds.

Every surviving failure is a *consumer* failure, not a producer one. The producer side is the larger omission: `project()` reads the whole record before building the reduced copy. The tiered design gathers identifiers into two departments of its own, concentrating identifier access into a single high-value target no adversary model here prices (Section 5). Prompt injection and side channels against the projection layer are out of scope. Projection bounds what an injected instruction reaches, not whether it executes. A mistake that never crosses that bound falls outside the metric.

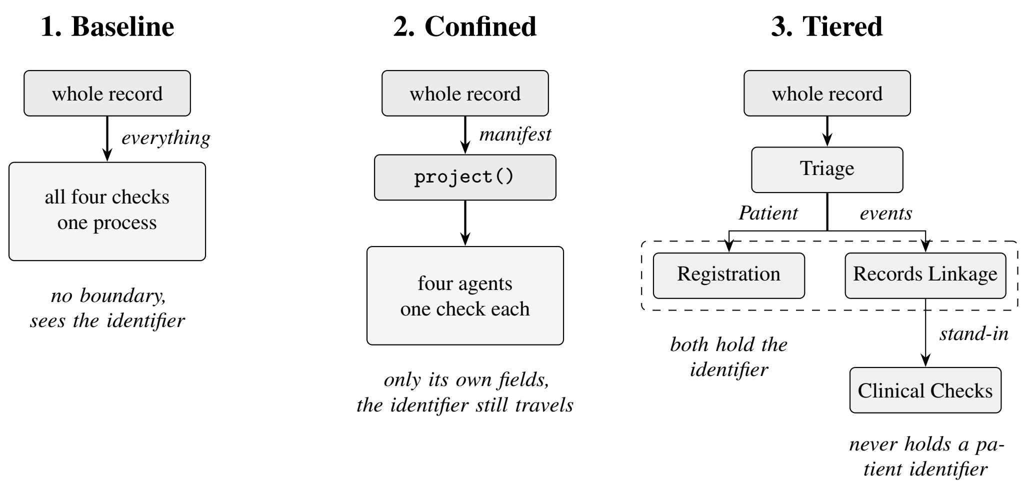
3 Method

The study runs one data-quality task through three designs, then narrows what a checker may read, one field at a time, and prices the effect on detection.

3.1 The three designs

Figure 1

Where the patient identifier reaches in each design. Only Tiered stops it, at Records Linkage.



The three designs differ only in what each part may read (Figure 1).

- **Baseline.** One program with full sight, each check receiving the whole resource, patient reference included.
- **Confined.** The same checks split into four agents, one per dimension, each with its own JSONPath manifest (Section 1). `project()` applies them as the single enforcement point across three widths, minimal, intermediate and full. Every event resource includes a patient reference, and no width withholds it from the checks that read it, so exposure barely moves (Section 4.5).
- **Tiered.** Asks the privacy question no manifest width reaches: who may hold an identifier at all. Four departments split the work. Triage routes each resource by its type and holds nothing. Registration takes the Patient records, holding identifiers. **Records Linkage** takes the event resources, resolving the patient reference *once* and replacing it with a **stand-in**. **Clinical Checks** runs the checks on that stand-in and never holds a patient identifier.

The stand-in is the next value of a seeded counter, not derived from what it replaces and stable within a run. Consistency is model-backed and excluded from this pipeline, leaving three of four dimensions scored. Section 4.6 prices three linkage settings: **Direct reference**, the raw reference passed through; **Stand-in**, the tiered arrangement; and **No linkage**, a floor that deletes the field.

3.2 Controls, defects and the privilege ablation

The **controlled comparison** sets Baseline against Confined. The two compare only if data, defects and checking rule are identical. A **defect** is a deliberate corruption of one field in one resource, one kind per dimension (Section 2).

- **Completeness.** The field is removed.
- **Plausibility.** The value is overwritten.
- **Consistency.** An encounter is given an end before its start.
- **Timeliness.** The timestamp is pushed far into the future.

Defects come from a seeded generator and are paired across the two systems so both see byte-identical records. The injector records every corrupted location as ground truth. Two controls keep the comparison fair.

First, there must be enough defects to find. The **kind-first** allocator chooses the *kind* of defect before asking whether the cohort can supply it, so at rate 0.10 it leaves **2** plausibility defects in a cohort of 200 and no consistency defects. That dimension is never tested. The **capability-first** allocator, called *stratified* in the tables and the result files, checks what the cohort can supply first. At rate 0.30 it leaves each cohort 27 to 29 plausibility defects and 7 to 9 consistency ones.

Second, both systems must run the same check. Both read one rule file, `manifests/rules/loinc_ranges.yaml`, whose bounds mark survivability, not reference intervals, so abnormal but survivable values pass. The file was itself corrected where it had been fitted to these cohorts. Appendix D gives its composition, the corrected bounds and the allowlist replacing them.

The injector runs in two modes. `legacy` substitutes one of four constants, -9999, 9999, 10^9 or -1.

`hard` reads the analyte's bound and places the value **2 to 15 per cent outside it**, every emitted value verified outside its bound before return.

No legacy constant collides with the evaluated selection, though three MIMIC-IV readings in the wider corpus match one (Appendix D). That cleanliness is the weakness: against `legacy` a five-line set-membership test scores $F1 = 1.0000$, a **saturated** endpoint that cannot rank detectors. `hard` removes the shortcut at source, its output reading like a value for that analyte, a heart rate of 389 per minute.

The controlled comparison gives both systems the same fields, so it cannot price the boundary. The ablation narrows the manifest past what the check needs and rescores. That is the study's primary measurement. One **arm** withholds a single JSONPath from the Confined manifests, everything else held fixed, and five arms run over the same twelve cells at rate 0.30. Three withhold a field the plausibility check **consumes**, the analyte code, the value and the unit. `control_minimal` withholds nothing, fixing what an unmodified manifest scores; `ucum_code` withholds `$.valueQuantity.code`, released by each width and read by no check, the negative control.

An arm's cost is the largest absolute gap between Baseline and Confined across its twelve cells, in percentage points of F1, reported alongside the mean Confined F1 over those cells. Section 4.3 re-runs all five under the hard injector.

3.3 Cohorts

Three public FHIR-shaped cohorts supply all the results.

- **Synthea** (Walonoski et al., 2018).
- **MIMIC-IV Clinical Database Demo v2.2** (Johnson, Bulgarelli, Pollard, et al., 2023; full release in Johnson, Bulgarelli, Shen, et al., 2023). All 100 subjects are converted.
- **eICU Collaborative Research Database Demo v2.0.1** (Johnson et al., 2021; full release in Pollard et al., 2018). From its 2,500-plus stays the study takes a **100-stay subsample**, one Encounter per Patient.

A **cell** is one scored run at one seed, cohort and manifest-width setting. A seed-by-cohort table has twelve cells, a seed-pooled cohort-by-width table nine, and a table crossing all three has 36. Every cell evaluates $N = 200$ resources, 66 of them Patient records.

The artefact of record is the converted bundles, not the source CSVs, and the adapter ships, so both PhysioNet cohorts rebuild. Synthea cannot. No generator seed was recorded, leaving it verifiable only by digest.

3.4 Metrics, and what does not reproduce

Detection is scored as F1 per dimension over resources, with **plausibility pre-declared as the single primary endpoint** able to move between systems.

Inter-agent exposure counts Safe Harbor fields: T_r is the count present in resource r and E_r the count released across agent boundaries and slices, so a shared field counts once per agent. Resources with $T_r = 0$ are dropped. The measure is *motivated by* AgentLeak (El Yagoubi et al., 2026), not taken from it.

Two aggregations appear here. The manifest-width sweep of Section 4.5 averages the ratio per resource, over the surviving set $\mathscr{R}$:

$$\frac{1}{|\mathscr{R}|} \sum_{r \in \mathscr{R}} \min\left(1, \frac{E_r}{T_r}\right).$$

The tiered run of Section 4.6 instead sums both counts across the resources of a cell and divides once,

$$\frac{\sum_r \min(E_r, T_r)}{\sum_r T_r},$$

then averages those per-cell ratios. That weights a resource by how much it had to expose. Because figures computed the two ways are not comparable, each exposure table names its aggregation.

The width sweep alone has a basis inconsistency. E_r counts the injected copy of a resource and T_r the clean one, so a deleted Safe Harbor field can vanish from the numerator while the denominator still counts it.

Not every run calls a model. Completeness and timeliness are rule-only. Plausibility and consistency call a language-model agent, Claude Haiku 4.5 at temperature `0.0`. The controlled comparison, the privilege ablation and the tiered run call no model, scoring plausibility from the shared rule file of Section 3.2.

Reproducibility note. The model-backed results do not fully reproduce. 478 of 1,800 payload lookups in a run lack a cache entry: only non-`uncertain` verdicts are cached, so uncached lookups replay as `uncertain`. Offline replay differs on **18 of 60** *legacy-configuration* scores, maximum delta **0.2105**, and on **4 of 60** for *this paper's own* stratified run, maximum delta **0.0179**, from 426 uncached lookups. What reproduces is the harness, not the model-backed measurement inside it. The controlled comparison and privilege ablation regenerate byte for byte, `make reproduce` reports every offline artefact byte-identical, and `make test` returns 355 passed, 1 skipped and 0 failed.

Tools. The harness is 5,967 lines of Python 3.12 across twenty modules, with versions frozen in `requirements-lock.txt`. It uses no orchestration framework, since the measurement is of field projection and the orchestration layer had to be the one part that could not confound it. A LangGraph variant ships separately as a portability check. Everything else is pinned (Appendix D).

4 Findings

Cost precedes privacy. Sections 4.1 to 4.4 price the boundary and bound that price. Sections 4.5 and 4.6 measure exposure, on two aggregations that are not comparable.

4.1 The controlled comparison returns exactly zero, and the design forced that zero

Baseline and all three Confined widths (Section 3.1) score identically in all twelve seed-by-cohort cells of Section 3.3. The largest absolute gap is 0.0000 pp at every width, cell by cell in Table B1 (Appendix B). Nothing was withheld. Both systems consume the same three JSONPaths, `$.code.coding[*].code`, `$.valueQuantity.value` and `$.valueQuantity.unit`, and every width releases all three.

Two tests in `tests/test_controlled.py` fix this. Over 600 clean resources they assert identical inputs, identical verdicts, and the same 277 silent cases with no numeric value to judge. Over 2,400 injected resources they assert inputs only, so verdict equality there is an entailment from equal inputs into the same function, not a measurement.

The 0.0000 pp gap is an identity, invariant to seed and cohort for fixed manifests, and the four-seed replication adds no information about privilege.

The design should have caught this before the runs. The three widths were drawn from what a checker might plausibly be granted, not from what this checker consumes, and the two sets were never compared. That comparison is one pass over the manifests. Had it been made, at least one width would have withheld a consumed field and the primary comparison would have measured something. The ablation of Section 3.2 repairs the omission after the fact.

4.2 What projection actually costs

The five ablation arms of Section 3.2 price the boundary under the legacy injector, and the price runs from nothing to the whole check (Table 1).

Table 1

Privilege ablation, twelve cells per arm, stratified allocator at rate 0.30, ***legacy*** *injector. Mean conf. is the mean Confined F1 over the twelve cells, not a mean gap. Gaps are unsigned: the analyte-code arm's 3.85 pp is a gain, the rest a loss. Source:* `results/privilege_ablation.json`.

Arm	Field withheld	Consumed?	Mean conf.	Largest abs. gap
`control_minimal`	none	–	0.9851	0.0000 pp
`ucum_code`	`$.valueQuantity.code`	no	0.9851	0.0000 pp
`observation_code`	`$.code.coding[*].code`	yes	1.0000	3.85 pp
`observation_unit`	`$.valueQuantity.unit`	yes	0.8993	28.04 pp
`observation_value`	`$.valueQuantity.value`	yes	0.0000	**100.00** pp

The three consumed fields do not cost the same. Withholding the value destroys the check. The unit's twelve per-cell gaps average 8.57 pp against a largest absolute gap of 28.04 pp. Without the unit the unit-scoped rule key cannot be resolved, so a multi-unit code is judged against another analyte's bounds. Withholding the analyte code does the opposite. It is a *gain*, an accident of the injector (Section 4.3).

Withholding `$.valueQuantity.code`, the UCUM unit symbol, costs exactly 0.0000 pp. That negative control (Section 3.2) is narrow, and the `ucum_code` zero is a consistency check, not independent proof. Eight of twelve cells contain no such field, and in the remaining four every arm but the value arm already scores F1 1.0000.

On these three cohorts, this endpoint and this injector, the measured gap was 0.0000 pp where what is released is a superset of what is consumed. Where it is not, it was as large as 100 pp.

4.3 Making the task harder, and re-running the ablation on it

Under the legacy injector the two crude detectors outscore the careful one, scoring 1.0000 in 12 of 12 cells against a twelve-cell mean of 0.9851 for the per-analyte file. The hard injector (Section 3.2) removes that inversion: set-membership on the four legacy constants catches 0 of 83, the crude $[0, 9000]$ envelope 5 of 83. The per-analyte range check catches 83 of 83 (Table C1, Appendix C). The gap remains 0.0000 pp in all twelve cells (Table B2, Appendix B), because difficulty changes which values get flagged, not which fields get read.

Table 1's legacy injector is saturated (Section 5): withholding the analyte code there *gained* 3.85 pp, because the default $[0, 9000]$ envelope catches all four legacy constants. Under the hard injector the envelope catches only 5 of 83, and the same arm **costs 100.00 pp**, mean Confined F1 0.0987. That reversal is an artefact of the saturated endpoint, not a property of privilege. The unit arm rises to 33.60 pp.

Both zero rows stay at zero. The unmodified manifest and the released-but-unconsumed field still cost exactly 0.0000 pp, mean Confined F1 0.9944 (Table C2).

4.4 The benchmark marks a correct answer wrong, which bounds the cost figures above

No score in Sections 4.1 to 4.3 is sounder than its ground truth, and on eICU it is wrong in both directions. It contains a body temperature of 99.8 degrees Celsius, a Fahrenheit value labelled with a Celsius unit: real corruption that nothing injected. A truthful bound flags it, and the scoring counts that correct detection as a false positive, since the ground truth assumes every uninjected record clean. It is the only `known_corrupt_values` record (Section 3.2) inside the 200-resource evaluation slice.

Relabelling that allowlist as genuine defects lifts the twelve-cell mean plausibility F1 from 0.9851 to 0.9908, with 7 of 12 cells perfect. That relabelling has **not** been applied, because redefining ground truth after seeing the scores manufactures a result.

The second direction has no allowlist and no counterfactual, and nothing measures what the four such cases cost. Where the legacy injector writes 9999 into an analyte whose ceiling is legitimately above 9999, the injected value is credible and a truthful bound passes it, scored as a miss.

F1 therefore carries an unknown ground-truth error in both directions. The bound falls on the cost half alone: the privacy half is counted in released fields and never scored against injected ground truth. Appendix E documents how the error surfaced, the rest of the allowlist, and the four cases.

4.5 What the agents actually leak, and how little narrowing moves it

Projection moves inter-agent exposure (Section 3.4) very little on these three cohorts, averaged per resource. Baseline scores 1.0000 by construction. Pooled exposure runs 0.6100 to 0.6500 on Synthea, 0.6525 to 0.6550 on MIMIC-IV and 0.6600 to 0.6700 on eICU-CRD. Narrowing full to minimal moves it at most 0.0400.

Three things keep it high. Observations are at the 1.0000 ceiling in all nine cells, their only Safe Harbor content being subject and encounter references, released at every width to the checks that read them. The event fraction is fixed too, the `limit // 3` Patient quota leaving 134 event resources of 200. The mix inside it is not, since the Encounter/Observation split differs by cohort (Appendix E), with differing Safe Harbor content.

Pooled exposure differs more between cohorts than between widths. Only the Patient row moves with width in Table A1 (Appendix A), only on Synthea, where `$.birthDate` becomes readable at full width.

4.6 The tiered design: 98.6 per cent less exposure, at no measured cost on the three dimensions scored

The tiered design of Section 3.1 changes who may hold an identifier, scored over 36 cells per setting. Exposure here is the summed-count ratio of Section 3.4, not the per-resource mean of Section 4.5, and not comparable with the pooled figures above.

Table 2
Linkage settings (Section 3.1), 36 cells each. Exposure is the summed-count ratio of Section 3.4, not the per-resource mean of Table A1. Consistency is model-backed and excluded for determinism. Source: `results/tiered_departments.json`, `make tiered`.

Linkage setting	Design	Exposure	Completeness	Plausibility	Timeliness
Direct reference	flat	0.6079	1.0000	0.9851	0.6620
Stand-in	tiered	**0.0086**	1.0000	0.9851	0.6620
No linkage	floor	0.0086	0.1644	0.9851	0.6620

Exposure falls by 98.6 per cent, from 0.6079 to 0.0086. The mean understates it: exposure is exactly 0.0000 in 32 of the 36 cells, the residual being `$.birthDate` reaching Registration in the four Synthea cells at full width. Detection is unchanged to four decimal places on all three rule-only checks. The stand-in is doing the work, since deleting linkage reaches the same exposure but collapses completeness from 1.0000 to 0.1644, with no records left to join.

5 Limitations, risks and ethics

Validity. Ground truth assumes every uninjected record is clean and it is not. Real corruption correctly flagged scores as a false positive, a physiologically real injection as a miss (Section 4.4). Neither direction is measured. No F1 difference smaller than that unknown error is claimable, and that limit is the floor under every two-score cost claim in Section 4. Only the controlled comparison escapes. Its zero is an identity the design forced (Section 4.1), so the one intact result says nothing about privilege.

Missingness is only ever the injector's. Completeness scores detection of a required field the injector removed, so absence already in the three cohorts is labelled clean and a truthful fail against one is charged as a false positive. Nor can the harness separate a field the pipeline withheld from one never recorded. That is what the no-linkage floor of 0.1644 is (Section 4.6), deletion by policy scored as a data defect. The width sweep repeats it in the privacy metric, where a deleted Safe Harbor field leaves the numerator while the denominator still counts it (Section 3.4). The handling strategies Wells et al. (2013) set out for EHR-derived data are neither applied nor evaluated here, so completeness reports injected absence and nothing about how missing this data already is.

The legacy endpoint is saturated. A five-line set-membership test and the crude $[0, 9000]$ envelope score 1.0000 in all twelve cells, where the per-analyte rule file is perfect in only 5 (Section 4.3). Table 1 was measured there, so the analyte-code arm re-run under the hard injector turns a 3.85 pp gain into a 100.00 pp cost (Table C2, Section 4.3). Each arm is the minimal plausibility manifest minus exactly one JSONPath (Sections 3.2 and 4.2). An arm's cost is therefore a property of the injector and the overlap between released and consumed fields, not of privilege.

At rate 0.10 the capability-first allocator realises nine plausibility defects per cohort, against 27 to 29 at rate 0.30 (Section 3.2). In the model-backed run at that lower rate, the Confined minus Baseline gap at full manifest width changes sign on two of three cohorts, so the winner turns on a handful of resources.

The rule file has no changelog and no earlier copy. Of its corrected bounds, 27 trace to their own source notes and the twenty-eighth does not. That it was never fitted to these cohorts has no support outside the file itself.

Generalisability. The results are offline batches over files on disk, no live EHR, no clinician reading output. Free means free only on the one withheld field, one agent, one dimension and one rule measured. Latency, throughput, token cost and manifest-authoring burden are unmeasured, so the 98.6 per cent reduction of Section 4.6 may be unaffordable where every event resource routes through Records Linkage.

Each cell scores 200 resources from three demonstration cohorts, one a 100-stay subsample (Section 3.3), all synthetic or de-identified. All figures are small-sample, and exposure was counted only over already de-identified fields, never free text. Stratifying by age or sex would pull the birth date, a Safe Harbor identifier, back into the checker.

Bias. Population bias is unmeasured rather than small. The rule file sets its bounds outside the widest value compatible with a living patient, paediatric and critical-care extremes included, and whether the bounds achieve that is untested. No subgroup breakdown of detection performance is reported, so no number in Section 4 can be attributed to, or cleared for, any population.

Synthea generates its whole platelet-distribution-width series at roughly twenty times the real scale. The bound for that analyte is left deliberately wide, and a truthful one would flag all 304 records. The eICU aggregate codes inherit one widest bound across dozens of analytes (Appendix B). Both are instrument artefacts that inflate the score, so reading one cohort against another is unsafe.

The four seeds resample the injector only. Replication measures injector variability, not sampling error, and reading it as a statement about hospitals overstates every number.

The privacy claim. Substitution concentrates identifier access rather than removing it. Routing every identifier into Records Linkage or Registration manufactures a single high-value target that no adversary model here prices (Section 2.2).

Linkage remains possible, since the stand-in is stable within a run and no further (Section 3.1). What fell is exposure and not re-identification risk. An assembled record stays re-identifiable, and recognising the same patient next week, which any deployment needs, is untested. The residual 0.0086 is `$.birthDate` reaching Registration by design in the four Synthea cells at full width, the only Safe Harbor field the stand-in setting releases anywhere.

The metric counts occurrences of Safe Harbor fields crossing agent boundaries over a denominator this harness defines (Section 3.4). With no expert determination and no re-identification attempt, 0.0086 is this harness's internal ratio, not a demonstration of de-identification, and not comparable with the pooled figures of Section 4.5, which average the other way.

The AI instrument. The model here is a measured component, not an authoring tool: `claude-haiku-4-5-20251001` at temperature `0.0`, chosen for cost rather than accuracy. Consistency, being model-backed, is excluded from the tiered pipeline, leaving three of four dimensions scored

(Section 3.1).

Roughly a quarter of model lookups are unrecoverable (Section 3.4). Provider non-determinism is not the cause, since 40 payloads asked twice at temperature 0 returned 0 disagreements. Consistency, the dimension that depends on those lookups, goes unscored in the three runs calling no model. Only non-`uncertain` verdicts are cached, so the non-reproduction is a gap in the cache and not a finding about model variance. One model at one temperature on one task supports no claim about models in general, and every model-backed number here is a property of this instrument.

5.1 Data provenance, ethics and disclosure

All three datasets are public and need no credentialed data use agreement. Synthea is synthetic, MIMIC-IV and eICU-CRD de-identified demonstration releases. All three are pinned locally by SHA-256, so no access request can fail mid-study. No IRB review was sought. The same controls on identifiable records would need IRB approval and a data use agreement before a single run. That setting is where the privacy claim would be tested, and this study never enters it.

No re-identification was attempted. The model instrument receives only the projected slice `project()` builds from the manifest (Section 3.1), so no field outside a manifest reaches it, and that dispatch is the control measured.

Stand-in identifiers come from a seeded counter, never derived from the identifier they replace, as 45 C.F.R. §164.514(c)(1) requires of a re-identification code. Hashing the medical record number, which most would reach for, would not qualify. That covers one field. It does not cover the pipeline around it, and the result above is reduced exposure, not de-identification.

AI tooling use is disclosed in `AI_DISCLOSURE.md`, and the register of instrument defects, the items left open and the test-suite critique are in `codebase_audit/`.

6 Conclusion

Confining each checker to a field manifest cost nothing, but that zero is an identity the design forced rather than a measurement. The ablation is the measurement, and it splits in two. An unmodified manifest and a field released but never consumed stay at exactly zero under either injector. The analyte code does not: a 3.85 pp gain under the saturated legacy injector, a 100.00 pp loss under the hard one (Section 4.3).

Narrowing manifests is the wrong lever for privacy, because the checks that read a patient reference receive it at every width, and exposure moved by at most 0.0400 across the width sweep. Moving identifier resolution into a department of its own cut exposure by 98.6 per cent with detection unmoved on all three rule-only dimensions. Deleting the patient reference reaches the same exposure and collapses completeness. That 98.6 is a summed-count ratio and the 0.0400 a per-resource mean, kept apart by Section 3.4 and never read against each other.

Implications. A plausibility check of this kind needs a code, a value and a unit, none of them a Safe Harbor identifier. Where a checker appears to need the identifier, what it needs is that two records belong to one patient, and a stand-in stable within a run is enough for that. A cost claim about privilege is only as sound as the injector it was measured under, and a single injector will not support one. Other rules will differ, since stratifying by age or sex pulls the birth date back in. One design lesson comes from this study's own miss. Compare what each manifest releases against what the check consumes before fixing the widths. A sweep in which every width releases every consumed field cannot measure what confinement costs.

Further work. Four gaps follow from Section 5, none of them measured here: whether a stand-in stays stable across runs, which any deployment needs, and whether detection holds by subgroup. The others are what projection costs in latency, throughput and manifest-authoring effort, and whether two separately minimal manifests re-identify a patient in combination, which Section 2.2 names.

Every cost figure above is one quality dimension of four, measured against ground truth that is wrong in both directions and left that way. Redefining it after seeing the scores manufactures a result (Section 4.4).

References

El Emam, K., Jonker, E., Arbuckle, L., & Malin, B. (2011). A systematic review of re-identification attacks on health data. *PLoS ONE, 6*(12), e28071. https://doi.org/10.1371/journal.pone.0028071

El Yagoubi, F., Badu-Marfo, G., & Al Mallah, R. (2026). AgentLeak: A benchmark for internal-channel privacy leakage in multi-agent LLM systems. *IEEE Access, 14*, 94960–94978. https://doi.org/10.1109/ACCESS.2026.3704541

HL7 International. (2024). *SMART App Launch implementation guide* (Version 2.2.0). https://hl7.org/fhir/smart-app-launch/

Jacob, D., Alghamdi, E., Hu, Z., Alomair, B., & Wagner, D. (2025). *Preventing prompt injection with type-directed privilege separation* [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2509.25926

Johnson, A., Bulgarelli, L., Pollard, T., Horng, S., Celi, L. A., & Mark, R. (2023). *MIMIC-IV Clinical Database Demo* (Version 2.2) [Data set]. PhysioNet. https://doi.org/10.13026/dp1f-ex47

Johnson, A., Pollard, T., Badawi, O., & Raffa, J. (2021). *eICU Collaborative Research Database Demo* (Version 2.0.1) [Data set]. PhysioNet. https://doi.org/10.13026/4mxk-na84

Johnson, A. E. W., Bulgarelli, L., Shen, L., Gayles, A., Shammout, A., Horng, S., Pollard, T. J., Hao, S., Moody, B., Gow, B., Lehman, L. H., Celi, L. A., & Mark, R. G. (2023). MIMIC-IV, a freely accessible electronic health record dataset. *Scientific Data, 10*(1), Article 1. https://doi.org/10.1038/s41597-022-01899-x

Juneja, G., Pasupulati, J. N. S., Albalak, A., Hua, W., & Wang, W. Y. (2025). *MAGPIE: A benchmark for multi-agent contextual privacy evaluation* [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2510.15186

Kahn, M. G., Callahan, T. J., Barnard, J., Bauck, A. E., Brown, J., Davidson, B. N., Estiri, H., Goerg, C., Holve, E., Johnson, S. G., Liaw, S.-T., Hamilton-Lopez, M., Meeker, D., Ong, T.

C., Ryan, P., Shang, N., Weiskopf, N. G., Weng, C., Zozus, M. N., & Schilling, L. (2016). A harmonized data quality assessment terminology and framework for the secondary use of electronic health record data. *eGEMs, 4*(1), 18. https://doi.org/10.13063/2327-9214.1244

Mandel, J. C., Kreda, D. A., Mandl, K. D., Kohane, I. S., & Ramoni, R. B. (2016). SMART on FHIR: A standards-based, interoperable apps platform for electronic health records. *Journal of the American Medical Informatics Association, 23*(5), 899–908. https://doi.org/10.1093/jamia/ocv189

Neupane, S., Mittal, S., & Rahimi, S. (2025). *Towards a HIPAA compliant agentic AI system in healthcare* [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2504.17669

Pollard, T. J., Johnson, A. E. W., Raffa, J. D., Celi, L. A., Mark, R. G., & Badawi, O. (2018). The eICU Collaborative Research Database, a freely available multi-center database for critical care research. *Scientific Data, 5*(1), Article 180178. https://doi.org/10.1038/sdata.2018.178

Privacy of Individually Identifiable Health Information, 45 C.F.R. §§164.502(b), 164.514(b), 164.514(c), 164.514(d) (2013). https://www.ecfr.gov/current/title-45/part-164/subpart-E

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Shi, T., He, J., Wang, Z., Li, H., Wu, L., Guo, W., & Song, D. (2025). *Progent: Securing AI agents with privilege control* [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2504.11703

Sweeney, L. (2000). *Simple demographics often identify people uniquely* (Data Privacy Working Paper No. 3). Carnegie Mellon University. https://dataprivacylab.org/projects/identifiability/paper1.pdf

U.S. Department of Health and Human Services, Office for Civil Rights. (2012). *Guidance regarding methods for de-identification of protected health information in accordance with the Health Insurance Portability and Accountability Act (HIPAA) Privacy Rule*. https://www.hhs.gov/hipaa/for-professionals/special-topics/de-identification/index.html

Walonoski, J., Kramer, M., Nichols, J., Quina, A., Moesel, C., Hall, D., Duffett, C., Dube, K., Gallagher, T., & McLachlan, S. (2018). Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record. *Journal of the American Medical Informatics Association, 25*(3), 230–238. https://doi.org/10.1093/jamia/ocx079

Wells, B. J., Chagin, K. M., Nowacki, A. S., & Kattan, M. W. (2013). Strategies for handling missing data in electronic health record derived data. *eGEMs, 1*(3), 1035. https://doi.org/10.13063/2327-9214.1035

Weiskopf, N. G., & Weng, C. (2013). Methods and dimensions of electronic health record data quality assessment: Enabling reuse for clinical research. *Journal of the American Medical Informatics Association, 20*(1), 144–151. https://doi.org/10.1136/amiajnl-2011-000681

Appendix A

Exposure Decomposed by Resource Type

The pooled exposure figure in Section 4.5 is weighted by cohort composition rather than by any manifest, and Table A1 is that decomposition. One caveat: the pooled column takes its numerator on the injected copy of a resource and its denominator on the clean one, per the audit register shipped with the code. It is *not* the n-weighted mean of the three columns beside it and should not be reconstructed from them.

Table A1

Inter-agent exposure by resource type and manifest width, from `results/results_stratified_-model.json`. Figures are the per-resource mean of Section 3.4, not the summed-count ratio of Table 2. One component cell moves with width. The pooled column also moves, for the basis reason above.

Cohort	Width	Patient	Encounter	Observation	Pooled
Synthea	minimal	0.0000	0.5000	1.0000	0.6100
Synthea	intermediate	0.0000	0.5000	1.0000	0.6125
Synthea	full	**0.1138**	0.5000	1.0000	0.6500
MIMIC-IV	minimal	0.0000	1.0000	1.0000	0.6525
MIMIC-IV	intermediate	0.0000	1.0000	1.0000	0.6550
MIMIC-IV	full	0.0000	1.0000	1.0000	0.6550
eICU-CRD	minimal	0.0000	1.0000	1.0000	0.6600
eICU-CRD	intermediate	0.0000	1.0000	1.0000	0.6700
eICU-CRD	full	0.0000	1.0000	1.0000	0.6700

Appendix B

All Twelve Cells, Legacy and Hard Injector

Baseline and all three Confined widths return the same plausibility F1 in all twelve seed-by-cohort cells, so the largest absolute gap is 0.0000 pp throughout. Table B1 records that cell by cell. Section 4.1 explains the identity.

Table B1
Plausibility F1 across twelve seed-by-cohort cells, capability-first allocator at rate 0.30*. n is realised plausibility defects. Source:* `results/controlled_comparison.json`.

Seed	Cohort	n	Baseline	Conf. min	Conf. int	Conf. full
42	Synthea	27	1.0000	1.0000	1.0000	1.0000
42	MIMIC-IV Demo	27	1.0000	1.0000	1.0000	1.0000
42	eICU-CRD Demo	29	0.9655	0.9655	0.9655	0.9655
43	Synthea	27	1.0000	1.0000	1.0000	1.0000
43	MIMIC-IV Demo	27	0.9811	0.9811	0.9811	0.9811
43	eICU-CRD Demo	29	0.9831	0.9831	0.9831	0.9831
44	Synthea	27	1.0000	1.0000	1.0000	1.0000
44	MIMIC-IV Demo	27	0.9811	0.9811	0.9811	0.9811
44	eICU-CRD Demo	29	0.9831	0.9831	0.9831	0.9831
45	Synthea	27	1.0000	1.0000	1.0000	1.0000
45	MIMIC-IV Demo	27	0.9615	0.9615	0.9615	0.9615
45	eICU-CRD Demo	29	0.9655	0.9655	0.9655	0.9655
Largest absolute gap, all twelve cells, all three widths: **0.0000** pp						

Table B2 gives the cells behind the hard-injector result of Section 4.3. The gap column is 0.0000 in every cell, as under the legacy injector. New here is the comparison between the two Baseline columns.

The harder task produces the higher score. F1 rises in five cells and never falls. On MIMIC-IV at seed 45 it goes from 0.9615 to 1.0000. That looks backwards until the cause is named, and Section 4.4 names it.

- **The legacy injector was manufacturing false ground truth.** It draws uniformly from four constants, and when it draws 9999 the analyte may be one whose own bound in the rule file admits 9999. The eICU aggregate code pools creatine kinase with the transaminases and inherits

Table B2

Plausibility F1 under the hard injector, four seeds by three cohorts, rate 0.30. The legacy base *column is the same cell from Table B1. Sources:* `results/controlled_comparison_hard.json` *and* `results/controlled_comparison.json`.

Seed	Cohort	n	Legacy base	Hard base	Hard conf. min	Gap (pp)
42	Synthea	27	1.0000	1.0000	1.0000	0.0000
42	MIMIC-IV	27	1.0000	1.0000	1.0000	0.0000
42	eICU-CRD	29	0.9655	0.9831	0.9831	0.0000
43	Synthea	27	1.0000	1.0000	1.0000	0.0000
43	MIMIC-IV	27	0.9811	1.0000	1.0000	0.0000
43	eICU-CRD	29	0.9831	0.9831	0.9831	0.0000
44	Synthea	27	1.0000	1.0000	1.0000	0.0000
44	MIMIC-IV	27	0.9811	1.0000	1.0000	0.0000
44	eICU-CRD	29	0.9831	0.9831	0.9831	0.0000
45	Synthea	27	1.0000	1.0000	1.0000	0.0000
45	MIMIC-IV	27	**0.9615**	**1.0000**	1.0000	0.0000
45	eICU-CRD	29	0.9655	0.9831	0.9831	0.0000

the widest of their bounds, which admits 9999. The checker is right not to flag those, and the benchmark counts it as a miss.

- **The hard injector cannot do this.** It reads the analyte's own bound and places the value outside it, so every injected defect is a genuine defect by construction.
- **The residual** 0.9831 **on eICU-CRD is not an injection artefact.** It is the single real corrupt record, the body temperature of 99.8°C discussed in Section 4.4, correctly flagged and scored as a false positive.

So the hard injector both makes the task hard enough to rank detectors and removes a source of false ground truth from the ground truth itself.

Appendix C

The Hard Injector: Detector Ranking and Privilege Ablation

Table C1 ranks the three detectors on the 83 defects the hard injector places, and Table C2 re-runs the ablation against that injector. Section 4.3 states the results.

Table C1

Detector performance under the hard injector. Counts from `tests/test_inject_hard.py`, seed 42, rate 0.30, three cohorts pooled.

Detector	Caught	Rate
Set-membership on the four legacy constants	0 of 83	0%
Crude $[0, 9000]$ envelope	5 of 83	6%
Per-analyte range check	83 of 83	100%

Table C2

*The same ablation under the **hard** injector, twelve cells per arm. The analyte-code arm reverses from a 3.85 pp gain to a 100.00 pp loss. Columns read as in Table 1, and arm names carry a `withhold_` prefix in the result file, except `control_minimal`. Source: `results/privilege_-ablation_hard.json`, `make ablation-hard`.*

Arm	Field withheld	Consumed?	Mean conf.	Largest abs. gap
`control_minimal`	none	–	0.9944	0.0000 pp
`ucum_code`	`$.valueQuantity.code`	no	0.9944	0.0000 pp
`observation_code`	`$.code.coding[*].code`	yes	0.0987	**100.00** pp
`observation_unit`	`$.valueQuantity.unit`	yes	0.8990	33.60 pp
`observation_value`	`$.valueQuantity.value`	yes	0.0000	100.00 pp

Three things change and one does not.

- **The analyte code becomes essential.** The injected values are now clinically adjacent, and a generic envelope cannot separate them from real readings.
- **The unit becomes more valuable**, 33.60 pp against 28.04, for the same reason.
- **The control rises** from 0.9851 to 0.9944, because the hard injector cannot write a physiologically real value and call it a defect, so the false ground truth of Section 4.4 largely disappears.
- **Both zero rows stay at zero.**

Appendix D

Rule File Corrections and Run Pinning

Section 3.2 states that both systems read one rule file, `manifests/rules/loinc_ranges.yaml`, and that the file was corrected where it had been fitted to these cohorts. It contains 322 sourced entries, 321 per-analyte bounds and one default `[0, 9000]` envelope. These are the corrections.

- **Twenty-eight bounds were corrected.** Twenty-seven record their prior value in a source note. The twenty-eighth, the eICU temperature tightening below, was applied without one.
- **Two had been widened** to stop real records tripping the false-positive guard, and are now restored: eICU FiO_2 from 10000 back to 100, and eICU body temperature from `[0, 120]` back to `[10, 45]`.
- **In their place is a `known_corrupt_values` allowlist** of **3 entries covering 4 rows, all eICU**, and the guard now fails on any flagged real value not allowlisted.

Section 3.2 states that no legacy constant collides with the evaluated selection. 0 of 323 numeric `valueQuantity` readings in that selection match one of the four sentinel constants. Three MIMIC-IV base-excess readings of -1.0 mEq/L appear among the wider corpus's 55,624 values, outside that selection.

Section 3.4 states what does and does not reproduce. This is what everything else is pinned to, and `REPRODUCE.md` documents the procedure.

- **Contracts.** Every run writes a thirteen-key run contract. The decoding settings sit in the cache contract that fixes a cached verdict's meaning: snapshot `claude-haiku-4-5-20251001` at temperature `0.0`, under an output cap of 512 tokens and 1024 on retry.
- **Cache.** `codebase/.llm_cache/`, 2,005 verdicts plus the `CACHE_CONTRACT.json` the harness verifies before replay.
- **Environment and cohorts.** Pinned to the versions every published number was computed under, the cohorts by SHA-256 digest over each shipped file and over the *ordered* sequence the

loader selects. Order matters because the injector draws against position. Synthea supplies 100 patients as 123 Patient resources. The two PhysioNet cohorts (Section 3.3) are distributed under the Open Data Commons Open Database Licence v1.0.

Appendix E

The Ground-Truth Error and Cohort Composition

Section 4.4 states the ground-truth finding. This is the detail behind it.

- **How it surfaced.** Tightening the two eICU bounds in the shared rule file (Section 3.2) made the four eICU cells score *worse*. The corrected bound flags the 99.8 degrees Celsius body temperature, and the scoring calls that a false positive.
- **The rest of the allowlist.** `known_corrupt_values` names the eICU records a truthful bound is right to flag. Besides the temperature reading these are three FiO2 readings of 4000 and 10000 that no scored cell reaches, which is why the counterfactual of Section 4.4 moves on the temperature row alone.
- **The four false negatives**, where the analyte's legitimate ceiling sits above the 9999 the legacy injector writes. These are the eICU enzyme-activity aggregate (code 1, Units/L), MIMIC 50878 for aspartate aminotransferase, and MIMIC 51108 and 51109 for urine volume.

Section 4.5 points here for the Encounter/Observation split. Of the 134 event resources in each cohort, Synthea contributes 23 Encounters and 111 Observations, eICU-CRD 7 and 127.